Análise de arquivo suspeito

Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando se a análise defensiva do arquivo é apropriada

Vou começar consultando como ler esse tipo de arquivo corretamente. Em seguida faço a análise **sem executar o arquivo**, apenas inspecionando o conteúdo.

Ler as instruções da skill de leitura de arquivos antes de inspecionar o .pyc
Um `.pyc` é bytecode compilado do Python, então vou fazer apenas **análise estática**: o arquivo não será executado nem importado em nenhum momento. Primeiro, identificação básica.

Ran a command
`xxd` não está disponível; vou usar Python/`od` para o hexdump e verificar a versão do interpretador (o formato do bytecode depende da versão).

Ran 4 commands, searched the web

Conclusão: é malware. É um *loader/downloader* de primeiro estágio que esconde o endereço do servidor de comando e controle (C2) na blockchain da Solana. A análise foi só estática: o arquivo não foi executado nem importado.

Passo a passo

1. Identificação

- É bytecode Python 3.13 (magic number 3571), com 19.185 bytes, compilado de um `.py` de 15.554 bytes.
- O nome do fonte embutido é um hash hexadecimal (`1e6487b7…98168267.py`), sem relação com nenhum projeto legítimo.
- SHA-256: `5ab4ca08925d2a4edfca9782ff978f504127bacff4bb08d77875a4a5c9f0ae83`

2. Estrutura e strings

O `.pyc` não traz o código-fonte, mas nomes, constantes e docstrings sobrevivem à compilação. Apareceram:

- funções com nomes aleatórios (`fvzsrnzlh` , `scyzzvvy`);
- docstrings em russo, como "Проверка, находится ли система в России" (“verificar se o sistema está na Rússia”);
- nove endpoints RPC públicos da Solana e uma carteira Solana fixa;
- URLs do Node.js v22.9.0 para Windows, macOS e Linux;
- um modelo de JavaScript com `eval(atob(...))` .

3. Comportamento

Reconstruí o fluxo a partir das constantes, dos nomes e das docstrings:

1. **Exclusão da Rússia:** verifica idioma, nome de usuário, fuso horário e nomes de fusos russos. Se achar que está na Rússia, encerra sem fazer nada, um padrão típico de malware que evita alvos nesse país.
2. **Limite de frequência:** grava `~/init.json` com uma data e, aparentemente, só roda de novo depois de cerca de 2 dias.
3. **C2 na blockchain:** consulta a carteira `BjVeAj…o8SC` por meio dos nove RPCs, com fallback entre eles. Lê o campo *memo* da transação, que traz um JSON com um link em base64. O atacante muda o destino só postando outra transação, então não há domínio para derrubar.
4. **Download do payload:** baixa o conteúdo desse link. O IV e a chave de decifragem chegam em cabeçalhos HTTP da resposta, com os nomes codificados em base64 no código.
5. **Runtime próprio:** baixa o Node.js v22.9.0 de nodejs.org para a pasta do usuário.
6. **Execução oculta:** grava um `i.js` ao lado do script com `eval(atob('…'))` e o executa com o Node em segundo plano, sem janela e com a saída descartada.

4. Correlação com inteligência de ameaças

A carteira embutida no arquivo já foi associada à GlassWorm, campanha que usa tokens roubados do GitHub para injetar malware em centenas de repositórios Python. Relatórios técnicos sobre ela descrevem os mesmos elementos encontrados aqui: as docstrings em russo, os nove RPCs de fallback e o download do Node.js 22.9.0 para a pasta do usuário. Sobre o estágio final, um registro do ThreatFox para um servidor dessa campanha fala em payloads polimórficos cifrados com AES, que combinam roubo de carteiras cripto e um RAT. glassworm attack uses s… +2

Veredito final: malware, com confiança alta

Nenhum software legítimo reúne ao mesmo tempo C2 em memo de blockchain, exclusão de máquinas russas, download silencioso de um runtime e `eval` de código remoto cifrado em processo oculto.

Limites da análise:

- Não desmontei os opcodes, porque o bytecode 3.13 não é compatível com o Python 3.12 do ambiente. O fluxo vem de nomes, constantes e docstrings, e bate com os relatórios públicos.
- O JavaScript final não está no arquivo, pois vem do servidor. Não dá para afirmar o que rodaria hoje na sua máquina, embora os relatórios apontem stealer e RAT.

IOCs e o que procurar

- Carteira Solana (C2): `BjVeAjPrSKFiingBn4vZvghsGj9KCE8AJVtbc9S8o8SC`
- Artefatos no host:
  - `~/init.json`
  - `~/node-v22.9.0-*` (zip/tar e pasta)
  - um `i.js` ao lado do script
  - um processo `node` em segundo plano
- **Comportamento suspeito:** um processo Python baixando `node-v22.9.0-*` de nodejs.org e depois iniciando `node i.js`.

Se já foi executado

- Isole a máquina e procure os artefatos acima.
- Trate como comprometidos, e troque a partir de um dispositivo limpo: senhas salvas no navegador, tokens do GitHub/npm/PyPI, chaves SSH e credenciais de nuvem. Se houver carteiras cripto, mova os fundos para uma carteira nova.
- Se o arquivo veio de um repositório, procure código ofuscado recente e reescritas de histórico (force-push).

Se não foi executado, mantenha-o em quarentena e não o importe nem rode. Se me disser de onde ele veio (repositório, pacote, e-mail), ajudo a avaliar o alcance.

Qual é a categoria principal deste malware?

Respondendo a pergunta sobre a categoria do arquivo ▸

Trojan Downloader, mais especificamente um loader de primeiro estágio.

O arquivo não carrega o payload final dentro de si, o que o tornaria um *dropper*. O trabalho dele é buscar o endereço do servidor no memo da blockchain, baixar o código cifrado de lá, preparar o Node.js e executar tudo em segundo plano. Ele só abre caminho para o estágio seguinte.

Também não se encaixa como infostealer ou RAT, porque não há aqui código que colete credenciais ou carteiras, nem que receba comandos. Isso fica no estágio seguinte, que segundo um registro do ThreatFox sobre um servidor C2 dessa campanha, combina roubo de carteiras cripto e um RAT. Não é um worm, pois o arquivo não se espalha sozinho: a disseminação da campanha, com injeção em repositórios por meio de tokens roubados, é feita por outros meios. abuse

No contexto maior, é a peça de execução de um ataque à cadeia de suprimentos de software. As marcas mais distintivas são o C2 escondido em blockchain e a exclusão de máquinas russas.